Internship Program — Cybersecurity Internship

IFGICT — International Federation of Global & Green ICT

End-of-Year Internship Report 2026

Cyber Resilience by Design

Offensive Security Audits and a Cloud-Native Governance Blueprint Aligned with NIST CSF 2.0 and ISO/IEC 27001:2022

Prepared by:

Wissal EL BEKKALI

Cybersecurity Engineering , UIR

Academic Supervisor

Mrs. Hasna EL HAJI

Université Internationale de Rabat (UIR)

Internship Supervisor

Dr. KAYYALI

IFGICT

Internship period: June 11, 2026 – August 11, 2026 (2 months)

Academic year: 2025 / 2026

IFGICT — International Federation of Global & Green ICT — 66 West Flagler Street, Suite 900 #6918, Miami, FL 33130, USA

Document classification: Confidential

Acknowledgements

Before presenting this report, I would like to express my sincere thanks to everyone who contributed to the success of this internship and to the completion of this document.

I would first like to warmly thank my supervisor at IFGICT, Dr. KAYYALI, for his constant availability, valuable advice, and the trust he placed in me throughout these two months. His methodological guidance, both on the technical side (web security audits) and on the research side (alignment of the NIST CSF 2.0 and ISO/IEC 27001:2022 frameworks), was decisive in the quality of the work produced.

I would also like to thank the entire IFGICT — International Federation of Global & Green ICT — team for their welcome and for giving me the opportunity to work on concrete, formative assignments combining offensive practice (pentesting) with strategic research in cybersecurity governance.

Special thanks go to the teaching staff of my institution, whose quality of instruction allowed me to approach this internship with the necessary technical and methodological foundations.

Finally, I thank my family and those close to me for their unwavering support, which was an essential driving force throughout this professional experience.

Abstract

This report presents the complete outcome of a two-month internship (June 11 – August 11, 2026) carried out at IFGICT — International Federation of Global & Green ICT, under the supervision of Dr. KAYYALI. The internship was organized into two complementary tracks.

The first month was dedicated to a hands-on web security assessment (pentesting) mission. Six institutional organizations were fully assessed (authorized passive and active reconnaissance, HTTP header analysis, TLS/DNS configuration review, CMS fingerprinting, and attack-surface mapping), following the OWASP WSTG, PTES, OSSTMM, and NIST SP 800-115 methodologies. Each assessment resulted in a detailed report with severity-based vulnerability classification and a prioritized 30/60/90-day remediation plan.

The second month focused on a theoretical research mission studying the alignment between the NIST Cybersecurity Framework (CSF) 2.0 and ISO/IEC 27001:2022, with the goal of designing an integrated compliance matrix suited to cloud-native enterprises. This work was carried out over four weekly milestones: literature review, control mapping and gap analysis, design of a three-layer Integrated Cybersecurity Management Blueprint, and finally a strategic compliance crosswalk guide for auditors and C-level executives.

This report consolidates all of this work, presents the results obtained, the architecture diagrams produced, and an analysis of the business benefits of the proposed blueprint.

Keywords: Cybersecurity, Pentesting, Web Assessment, OWASP, NIST CSF 2.0, ISO/IEC 27001:2022, Cloud-native, Governance, Compliance, Blueprint.

List of Figures

3.1 General methodology applied to each web security audit 14

3.2 Overall distribution of the 76 findings identified across the six audits 15

4.1 Overview of the NIST CSF 2.0 × ISO/IEC 27001:2022 Annex A mapping (solid line = direct correlation, dotted line = partial correlation) 22

4.2 Three-layer architecture of the Integrated Cybersecurity Management Blueprint 23

4.3 CI/CD pipeline security gate implementing BP-CN-04 25

4.4 Dual-audience structure of the crosswalk compliance guide 25

4.5 Aggregated maturity by Blueprint layer (qualitative assessment, end of internship) 26

List of Tables

2.1 Overall internship schedule (2 months) 12
3.1 Summary of the six targets audited during month 1 15
3.2 Aggregated distribution of findings across the six audits 15
3.3 Key findings — IsDB 16
3.4 Key findings — SMIIC 16
3.5 Key findings — IEC 17
3.6 Key findings — AMF 17
3.7 Key findings — AWO 17
3.8 Key findings — ALECSO 17
3.9 Recurring vulnerability patterns across the campaign 18
4.1 The six functions of NIST CSF 2.0 19
4.2 The four themes of Annex A — ISO/IEC 27001:2022 20
4.3 Structural comparison of NIST CSF 2.0 vs. ISO/IEC 27001:2022 20
4.4 Excerpt of the NIST CSF 2.0 × ISO/IEC 27001:2022 mapping (Week 2) 21
4.5 The five cloud-native gaps identified in Week 2 22
4.6 Blueprint controls — Governance layer 24
4.7 Blueprint controls — Core Controls layer 24
4.8 Blueprint controls — Cloud-native Extension layer 24
4.9 Consolidated matrix of the Blueprint's 14 controls 25
4.10 Excerpt of the Auditor view — evidence and maturity per control 26
4.11 Recommended investment priorities by layer 27
4.12 Expected business benefits of the integrated Blueprint 27

List of Abbreviations

API	Application Programming Interface
CAA	Certification Authority Authorization
CI/CD	Continuous Integration / Continuous Deployment
CMS	Content Management System
CSF	Cybersecurity Framework (NIST)
CSP	Content Security Policy / Cloud Service Provider (depending on context)
CVE	Common Vulnerabilities and Exposures
DMARC	Domain-based Message Authentication, Reporting and Conformance
DNS	Domain Name System
DNSSEC	Domain Name System Security Extensions
EOL	End of Life
HSTS	HTTP Strict Transport Security
IaC	Infrastructure as Code
IdP	Identity Provider
ISMS	Information Security Management System
ISO/IEC	International Organization for Standardization / International Electrotechnical Commission
KMS	Key Management Service
NIST	National Institute of Standards and Technology
OSSTMM	Open Source Security Testing Methodology Manual
OWASP	Open Web Application Security Project
PTES	Penetration Testing Execution Standard
RCE	Remote Code Execution
SIEM	Security Information and Event Management
SoA	Statement of Applicability
SPF	Sender Policy Framework
TLS/SSL	Transport Layer Security / Secure Sockets Layer
UAT	User Acceptance Testing
WAF	Web Application Firewall
WSTG	Web Security Testing Guide (OWASP)

Table of Contents

Acknowledgements **2**

Abstract **3**

List of Figures **4**

List of Tables **5**

List of Abbreviations **6**

Table of Contents **7**

General Introduction 9

1 Presentation of the Host Organization 10

1.1 Introduction 10

1.2 Presentation of IFGICT 10

1.3 Missions and Business Units 10

1.4 Internship Supervision 10

1.5 Conclusion 11

2 General Context and Organization of the Internship 12

2.1 Introduction 12

2.2 Internship Objectives 12

2.3 Overall Internship Schedule 12

2.4 Methodologies and Frameworks Used 13

2.4.1 Hands-on track 13

2.4.2 Theoretical track 13

2.5 Conclusion 13

3 Hands-on Track: Web Security Audits (Month 1) 14

3.1 Introduction 14

3.2 Audit Methodology Applied 14

3.3 Summary of the Six Audits Performed 14

3.4 Aggregated Distribution of Vulnerabilities by Severity 15

3.5 Audit Details by Target 16

3.5.1 Islamic Development Bank (IsDB) — Grade D 16

3.5.2 SMIIC — Grade C 16

3.5.3 International Electrotechnical Commission (IEC) — Grade B 16

3.5.4 Arab Monetary Fund (AMF) — Grade B 17
3.5.5 Arab Women Organization (AWO) — Grade F 17
3.5.6 ALECSO — Grade F 17
3.6 Cross-Cutting Findings 17
3.7 Conclusion 18
4 Theoretical Track: Alignment of NIST CSF 2.0 × ISO/IEC 27001:2022 (Month 2) 19
4.1 Introduction and Research Objectives 19
4.2 Week 1 — Literature Review 19
4.2.1 NIST Cybersecurity Framework 2.0 19
4.2.2 ISO/IEC 27001:2022 19
4.2.3 Structural Comparison 20
4.3 Week 2 — Mapping of Correlations and Gaps 20
4.3.1 Mapping Methodology 20
4.3.2 Five Recurring Cloud-Native Gaps 21
4.4 Week 3 — Integrated Cybersecurity Management Blueprint 23
4.4.1 Three-Layer Architecture 23
4.4.2 Layer 1 — Governance and Risk Oversight 23
4.4.3 Layer 2 — Core Security Controls 24
4.4.4 Layer 3 — Cloud-Native Extensions 24
4.5 Week 4 — Crosswalk Compliance Guide 25
4.5.1 Dual-Audience Structure 25
4.5.2 Auditor View — Traceability and Maturity 26
4.5.3 Executive View — Maturity by Layer 26
4.6 Business Benefits of the Proposed Blueprint 27
4.7 Conclusion 28
General Conclusion 29
References 30

General Introduction

In a context where cyber threats are growing more complex and alignment with international frameworks is becoming a strategic issue for every organization, the combined mastery of offensive skills (auditing, pentesting) and strategic skills (governance, compliance, framework alignment) constitutes a major asset for a cybersecurity professional.

It is within this perspective that the two-month internship carried out at IFGICT — International Federation of Global & Green ICT, from June 11 to August 11, 2026, under the supervision of Dr. KAYYALI, takes place. This internship was deliberately structured into two complementary, sequential tracks:

- a hands-on track (month 1), dedicated to carrying out six complete web security audits on real institutional organizations, providing the opportunity to develop concrete expertise in reconnaissance, vulnerability analysis, and professional pentest reporting;
- a theoretical track (month 2), dedicated to a strategic research mission on the alignment between the NIST Cybersecurity Framework (CSF) 2.0 and ISO/IEC 27001:2022, resulting in the design of a cybersecurity management blueprint and a crosswalk compliance guide for cloud-native environments.

This report aims to present, in a structured and comprehensive manner, all of the work carried out during these two months. It is organized into four chapters:

- Chapter 1 presents the host organization, IFGICT, its missions, and its organization.
- Chapter 2 details the general context of the internship: objectives, schedule, and methodologies used.
- Chapter 3 presents the hands-on track in detail: the six web security audits carried out during the first month.
- Chapter 4 presents the theoretical track: the research on the NIST CSF 2.0 × ISO/IEC 27001:2022 alignment, the resulting integrated blueprint, and its expected business benefits.

A general conclusion closes this report, summarizing the skills acquired and the professional prospects opened up by this internship.

Chapter 1 — Presentation of the Host Organization

1.1 Introduction

This chapter presents the internship's host organization, IFGICT — International Federation of Global & Green ICT, its missions, its organization, and the supervisory framework put in place for this internship.

1.2 Presentation of IFGICT

IFGICT (International Federation of Global & Green ICT) is an international organization active in the fields of information technology, cybersecurity, and responsible digital technology ("Green ICT"). It notably offers internship and hands-on training programs in cybersecurity, combining operational exposure (audits, penetration testing) with applied research assignments on international information security frameworks and standards.

Field	Detail
Name	International Federation of Global & Green ICT (IFGICT)
Areas of activity	Cybersecurity, audit & pentesting, governance and compliance, green information technologies
Address	66 West Flagler Street, Suite 900 #6918, Miami, FL 33130, USA
Contact	Tel. +1 786-204-2313 (USA)

1.3 Missions and Business Units

IFGICT organizes its activities around several complementary areas:

- Offensive cybersecurity: carrying out web security audits and vulnerability assessments for partner organizations, following recognized methodologies (OWASP, PTES, OSSTMM).
- Governance and compliance: support in aligning with international frameworks (NIST, ISO/IEC), production of strategic guides and blueprints.
- Training and mentoring of interns: a structured internship program combining hands-on learning and applied research, with individualized supervision.
- Green ICT: promotion of responsible and sustainable digital practices within IT infrastructures.

1.4 Internship Supervision

The internship was supervised by Dr. KAYYALI, IFGICT's technical and methodological point of contact, who provided weekly follow-up on both tracks of the internship: validating the security audit reports during the first month, then critically reviewing and providing constructive

feedback on the research deliverables (mapping, blueprint, compliance guide) during the second month.

1.5 Conclusion

Having presented the host organization, the next chapter details the general context of the internship, its objectives, and the overall methodology adopted.

Chapter 2 — General Context and Organization of the Internship

2.1 Introduction

This chapter presents the objectives of the internship, its organization over two months, and the methodological frameworks used for each of the two tracks.

2.2 Internship Objectives

The internship pursued a dual pedagogical and professional objective:

- develop operational expertise in web security auditing, from reconnaissance through to writing professional reports usable by decision-makers;
- develop strategic expertise in cybersecurity governance, through a comparative study of two major international frameworks and the production of a cloud-native-oriented compliance deliverable.

2.3 Overall Internship Schedule

The internship ran over eight weeks, from June 11 to August 11, 2026, split into two homogeneous four-week blocks.

Period	Track	Content
Weeks 1–4 (06/11 – 07/09/2026)	Hands-on	Carrying out 6 complete web security audits (reconnaissance, analysis, report writing)
Week 5 (07/10 – 07/17/2026)	Theoretical	Literature review: NIST CSF 2.0 and ISO/IEC 27001:2022
Week 6 (07/18 – 07/24/2026)	Theoretical	Mapping of correlations and cloud-native gaps
Week 7 (07/25 – 07/31/2026)	Theoretical	Design of the integrated cybersecurity management blueprint
Week 8 (08/01 – 08/11/2026)	Theoretical	Finalization of the crosswalk compliance guide and the final report

Table 2.1: Overall internship schedule (2 months)

> ***Key takeaway.*** *The internship was structured to move the intern from an operational posture (identifying concrete vulnerabilities) toward a strategic posture (aligning those findings with recognized governance frameworks), reflecting a coherent skills progression across the full cybersecurity career path.*

2.4 Methodologies and Frameworks Used

2.4.1 Hands-on track

The six web security audits were conducted using the following frameworks: OWASP Web Security Testing Guide (WSTG) v4.2, OWASP Top 10 2021, Penetration Testing Execution Standard (PTES), Open Source Security Testing Methodology Manual (OSSTMM), and NIST SP 800-115.

2.4.2 Theoretical track

The research drew on two international frameworks: the NIST Cybersecurity Framework (CSF) 2.0 (published in February 2024) and the ISO/IEC 27001:2022 standard, along with its associated implementation guide, ISO/IEC 27002:2022.

2.5 Conclusion

With this methodological framework established, the next two chapters address in detail the work carried out during each of the internship's two tracks.

Chapter 3 — Hands-on Track: Web Security Audits (Month 1)

3.1 Introduction

This chapter presents in detail the work carried out during the first month of the internship: six complete web security audits, conducted on real institutional organizations, following a rigorous methodology from reconnaissance through to prioritized remediation.

3.2 Audit Methodology Applied

Each audit followed a four-stage process, illustrated in Figure 3.1.

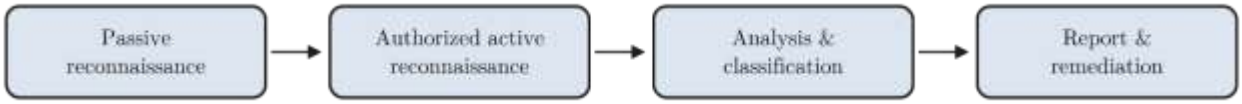


Figure 3.1: General methodology applied to each web security audit

> ***Key takeaway.*** *This methodological chain — reconnaissance, analysis, reporting — ensures that every identified vulnerability is traceable (tool, technical evidence) and actionable (prioritized recommendation), a necessary condition for a pentest report to be usable by both technical teams and non-technical decision-makers.*

The following tools were used recurrently: whois, dig/nslookup, curl, Nmap, WhatWeb, Qualys SSL Labs, SecurityHeaders.com, and crt.sh, complemented by manual interpretation of results.

3.3 Summary of the Six Audits Performed

Target	Grade	Main finding
Islamic Development Bank (IsDB)	D — Poor	Obsolete CMS Drupal 8 (EOL), over 40 exposed subdomains, several of them UAT/test environments
SMIIC	C — Acceptable	Obsolete PHP 7.1.33 (EOL), 5 missing HTTP security headers
IEC	B — Good	6 missing HTTP headers, overly permissive CORS policy (Access-Control-Allow-Origin: *)
Arab Monetary Fund (AMF)	B — Good	Missing CSP, DMARC set to p=reject but without internal monitoring
Arab Women Organization (AWO)	F — Unacceptable	No HTTPS at all, no SPF or DMARC record
ALECSO	F — Unacceptable	Obsolete Joomla 3.9.3 and PHP 7.2.34 (potential RCE), exposed FTP service

Table 3.1: Summary of the six targets audited during month 1

Key takeaway. *Of the six organizations audited, two received a grade of F (unacceptable), revealing critical gaps (no encryption, exploitable obsolete components), while three received a grade of B, demonstrating an overall satisfactory but improvable security posture regarding HTTP headers and DNS monitoring. No target achieved an A grade, confirming that hardening security headers and managing the software component lifecycle remain recurring blind spots, even for mature organizations.*

3.4 Aggregated Distribution of Vulnerabilities by Severity

Target	Critical	High	Medium	Low	Info.	Total
IsDB	1	1	4	3	4	13
SMIIC	0	0	6	5	4	15
IEC	0	0	6	3	3	12
AMF	0	0	3	4	3	10
AWO	2	0	4	3	4	13
ALECSO	2	0	4	3	4	13
Total	5	1	27	21	22	76

Table 3.2: Aggregated distribution of findings across the six audits

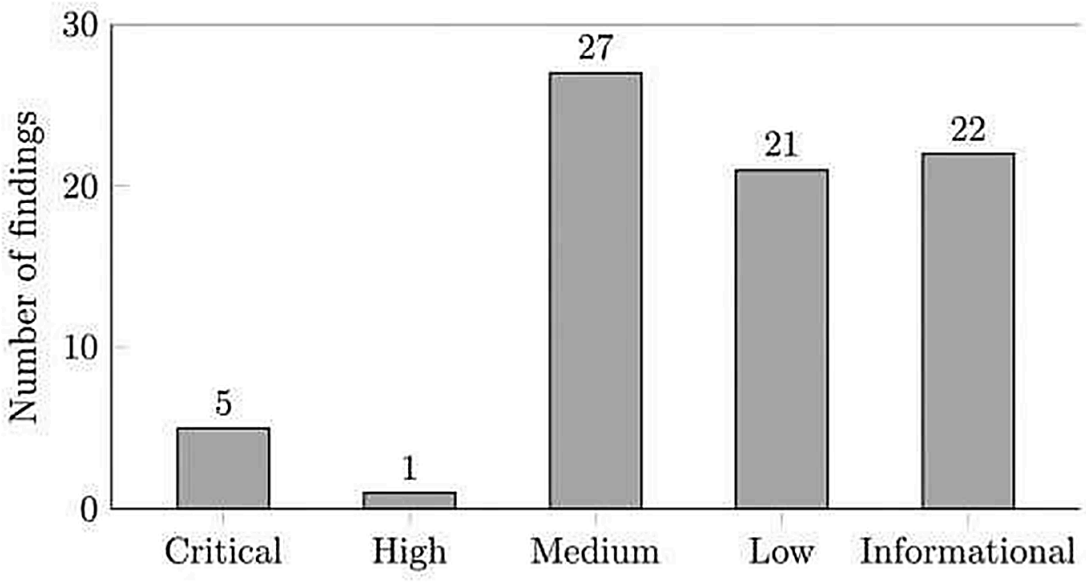


Figure 3.2: Overall distribution of the 76 findings identified across the six audits

Key takeaway. Medium-severity vulnerabilities dominate by a wide margin (27 out of 76, i.e., 35%), mainly related to missing HTTP security headers (CSP, HSTS, X-Frame-Options). This finding highlights that a significant share of risk could be reduced quickly through simple, low-

cost configuration changes, well before undertaking heavier application-modernization efforts (CMS upgrades, PHP migration).

3.5 Audit Details by Target

3.5.1 Islamic Development Bank (IsDB) — Grade D

The audit of https://www.isdb.org/ revealed an end-of-life Drupal 8 CMS (EOL since November 2021), exposed via the X-Generator header, as well as an extensive attack surface: more than 40 subdomains discovered via certificate transparency logs (crt.sh), including several test/UAT environments (acttest.isdb.org, ssc-uat.isdb.org, etc.) potentially less hardened than production.

Severity	Finding
Critical	Obsolete Drupal 8 CMS, unpatched since late 2021
High	Over 40 exposed subdomains, including several UAT/test environments
Medium	CSP, HSTS, Referrer-Policy, and Permissions-Policy missing

Table 3.3: Key findings — IsDB

3.5.2 SMIIC — Grade C

The audit of https://smiic.org/en revealed an obsolete PHP 7.1.33 version (EOL since December 2019) as well as five missing HTTP security headers (CSP, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy). The TLS certificate was properly configured (Grade A), but the domain was due to expire within a critical 47-day window at the time of the audit.

Severity	Finding
Medium	Obsolete PHP 7.1.33 (EOL), HTTP → HTTPS redirection not enforced
Low	DNSSEC not enabled, DNS CAA not configured, XSRF cookie without HttpOnly
Info.	Domain expiring in 47 days

Table 3.4: Key findings — SMIIC

3.5.3 International Electrotechnical Commission (IEC) — Grade B

The audit of https://www.iec.ch showed an overall solid infrastructure (Amazon CloudFront, active WAF, TLS Grade A), but six HTTP security headers were still absent (HSTS, CSP, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy) and an overly permissive CORS policy (Access-Control-Allow-Origin: *) was noted.

Severity	Finding
Medium	Six missing HTTP security headers
Low	CORS set to *, DNSSEC not enabled, DNS CAA absent

Info.	DMARC set to p=quarantine rather than p=reject

Table 3.5: Key findings — IEC

3.5.4 Arab Monetary Fund (AMF) — Grade B

The audit of https://www.amf.org.ae revealed a solid security posture (HSTS, X-Frame-Options, X-Content-Type-Options, and Permissions-Policy correctly configured, active Imperva WAF), but the absence of a Content-Security-Policy and a DMARC policy (p=reject) whose reports are sent only to a third-party analyst, with no internal visibility, were noted.

Severity	Finding
Medium	CSP absent, DMARC without internal monitoring, CMS fingerprinting via robots.txt
Low	DNS CAA absent, DNSSEC not enabled

Table 3.6: Key findings — AMF

3.5.5 Arab Women Organization (AWO) — Grade F

The audit of http://www.arabwomenorg.org revealed the most critical findings of the campaign: the site is served exclusively over HTTP, with no functioning TLS certificate, and no SPF or DMARC record is configured, making full email identity spoofing of the domain possible.

Severity	Finding
Critical	Total absence of HTTPS; no SPF or DMARC (email spoofing possible)
Medium	Five missing HTTP security headers; obsolete ASP.NET and jQuery 1.7.2

Table 3.7: Key findings — AWO

3.5.6 ALECSO — Grade F

The audit of https://www.alecso.org/nsite/ar/ revealed a Joomla 3.9.3 CMS and a PHP 7.2.34 runtime, both obsolete and carrying known vulnerabilities that could lead to remote code execution (RCE), as well as an FTP service exposed to the Internet (anonymous login, however, was rejected).

Severity	Finding
Critical	Obsolete Joomla 3.9.3 and PHP 7.2.34, potential RCE
Medium	Internet-exposed FTP service (vsftpd), missing CSP/HSTS/X-Frame-Options

Table 3.8: Key findings — ALECSO

3.6 Cross-Cutting Findings

Cross-analysis of the six audits reveals recurring patterns, regardless of the sector or apparent maturity of the organization.

Recurring pattern	Occurrences	Targets concerned
Missing HTTP security headers (notably CSP)	6/6	All audited targets
DNSSEC not enabled	5/6	IsDB, SMIIC, IEC, AMF, AWO
DNS CAA not configured	5/6	IsDB, SMIIC, IEC, AMF, AWO
Obsolete software component (CMS/runtime)	4/6	IsDB, SMIIC, AWO, ALECSO
Technology stack disclosure (headers/robots.txt)	6/6	All audited targets

Table 3.9: Recurring vulnerability patterns across the campaign

Key takeaway. The near-systematic absence of Content-Security-Policy and DNSSEC, across organizations otherwise heterogeneous in size and sector, suggests a need for broad awareness-raising rather than an isolated flaw. This finding directly motivated, during the second month of the internship, the decision to propose a structuring governance framework (blueprint) rather than limiting the output to ad hoc, project-by-project recommendations.

3.7 Conclusion

This first month made it possible to carry out six complete web security audits, from reconnaissance to prioritized remediation, revealing highly contrasted maturity levels (from F to B) and recurring vulnerability patterns. These field findings directly fed into the reflection of the second month, dedicated to designing a structuring governance framework.

Chapter 4 — Theoretical Track: Alignment of NIST CSF 2.0 × ISO/IEC 27001:2022 (Month 2)

4.1 Introduction and Research Objectives

The second month of the internship was devoted to a strategic research mission aiming to answer the following question: how can the NIST Cybersecurity Framework (CSF) 2.0 and ISO/IEC 27001:2022 be aligned in order to produce an integrated compliance matrix directly usable by cloud-native enterprises? This mission ran over four weeks, each producing an intermediate deliverable validated by Dr. KAYYALI.

4.2 Week 1 — Literature Review

4.2.1 NIST Cybersecurity Framework 2.0

Published in February 2024, NIST CSF 2.0 organizes cybersecurity outcomes into six high-level functions. The major novelty of this version is the addition of the Govern function, reflecting the need to treat cyber risk as an enterprise risk, owned at the leadership level.

Function	Purpose	Key question
Govern (GV)	Strategy, roles, policy, and oversight of cyber risk management	Are our decisions aligned with business objectives?
Identify (ID)	Understanding of assets, data, systems, and associated risks	What do we have, and what could happen?
Protect (PR)	Safeguards ensuring the continuity of critical services	How do we limit the impact of an incident?
Detect (DE)	Timely detection of anomalies and indicators of compromise	Do we detect incidents quickly?
Respond (RS)	Actions taken once an incident has been detected	What do we do once an incident is detected?
Recover (RC)	Restoration of affected capabilities and services, lessons learned	How do we return to normal?

Table 4.1: The six functions of NIST CSF 2.0

Key takeaway. The addition of the Govern function is the defining structural change in CSF 2.0: it explicitly elevates cybersecurity to the rank of an enterprise risk, making it the natural anchor point for any alignment exercise with a management system such as ISO/IEC 27001, whose clauses 5 and 6 already cover leadership and planning.

4.2.2 ISO/IEC 27001:2022

ISO/IEC 27001:2022 is a certifiable standard defining the requirements for establishing, implementing, maintaining, and improving an information security management system (ISMS).

Clauses 4 through 10 define the mandatory requirements of the management system, while Annex A offers a set of 93 controls, reorganized in 2022 into four themes.

Annex A theme	Controls	Scope
A.5 — Organizational controls	37	Policies, roles, supplier relationships, threat intelligence, incident management, continuity
A.6 — People controls	8	Screening, terms of employment, awareness, disciplinary process, remote work
A.7 — Physical controls	14	Secure areas, equipment protection, clear desk, media handling
A.8 — Technological controls	34	Access control, cryptography, secure configuration, anti-malware defense, logging, cloud services

Table 4.2: The four themes of Annex A — ISO/IEC 27001:2022

4.2.3 Structural Comparison

Dimension	NIST CSF 2.0	ISO/IEC 27001:2022
Nature	Voluntary framework, common language	Certifiable standard, mandatory requirements (clauses 4–10)
Structure	6 functions → categories → subcategories	Clauses 4–10 + Annex A (93 controls, 4 themes)
Governance	Dedicated Govern function (new in 2.0)	Integrated into clauses 5–6 and A.5 controls
Certification	None (self-assessment via Tiers/Profiles)	Third-party certification possible
Language	Expected outcomes ("what")	Prescriptive, auditable controls ("how")

Table 4.3: Structural comparison of NIST CSF 2.0 vs. ISO/IEC 27001:2022

Key takeaway. The two frameworks differ in nature but are complementary: CSF 2.0 expresses expected outcomes, while ISO/IEC 27001 provides precise, auditable controls. This complementarity justifies the value of a crosswalk mapping rather than an exclusive choice of one over the other.

4.3 Week 2 — Mapping of Correlations and Gaps

4.3.1 Mapping Methodology

A representative sample of CSF 2.0 subcategories was compared against the closest Annex A control, using a qualitative classification of Direct (clear correspondence) or Partial (real link but non-equivalent scope), together with a systematic assessment of the cloud-native applicability of each pair.

CSF subcategory	ISO control	Corr.	Cloud-native note

GV.OC-01 (stakeholder expectations)	A.5.1 (policies)	Partial	Must clarify shared-responsibility boundaries with CSPs
GV.SC-01 (supplier risk strategy)	A.5.19–5.23 (supplier relationships)	Direct	A.5.23 (cloud services) is the natural anchor for CSP risk
ID.AM-01 (hardware inventory)	A.5.9 (asset inventory)	Partial	The static model struggles to cover ephemeral assets (containers, serverless)
ID.RA-01 (identified vulnerabilities)	A.8.8 (technical vulnerability management)	Direct	To be extended to container images and IaC templates
PR.AA-01 (identity management)	A.5.16 + A.8.2	Direct	Multi-cloud identity federation (SSO/IdP) to be explicitly documented
PR.DS-01 (data-at-rest protection)	A.8.24 (cryptography)	Direct	Well covered; to be extended to CSP-managed key stores (KMS)
DE.CM-01 (network monitoring)	A.8.16 (monitoring activities)	Direct	Multi-cloud log aggregation to a central SIEM
RS.MA-01 (response plan execution)	A.5.24–5.26 (incident management)	Direct	Must clarify CSP incident-notification SLAs
RC.RP-01 (recovery plan execution)	A.5.29–5.30 (ICT continuity)	Direct	Multi-region failover testing not explicit in either framework

Table 4.4: Excerpt of the NIST CSF 2.0 × ISO/IEC 27001:2022 mapping (Week 2)

Key takeaway. The majority of CSF 2.0 subcategories find at least a Partial correspondence in Annex A, confirming the strong complementarity of the two frameworks. The Govern and Identify functions show the most direct correlations, as they rely on organizational controls (A.5.x) that are already very detailed in ISO/IEC 27001. Conversely, the Detect and Respond functions concentrate the most significant gaps with respect to modern cloud-native practices.

4.3.2 Five Recurring Cloud-Native Gaps

The mapping exercise identified five areas of insufficient overlap, as neither framework was designed in an era of massive Kubernetes and Infrastructure-as-Code adoption.

Cloud-native gap	Why overlap is insufficient	Recommended treatment
Container & Kubernetes security	Neither Docker nor Kubernetes is explicitly named	Image scanning, admission control

		(OPA Gatekeeper, Kyverno)
Multi-cloud identity federation	PR.AA-01/A.5.16 assume a single directory	Documented federation model with a break-glass fallback procedure
Data residency and sovereignty	Both frameworks are jurisdiction-agnostic	Per-region notification matrix
Ephemeral asset inventory	A.5.9/ID.AM assume relatively static assets	Inventory continuously fed by the cloud provider's API
Infrastructure-as-Code drift	Configuration-management controls predate widespread IaC adoption	Automated IaC scanning integrated into the CI/CD pipeline

Table 4.5: The five cloud-native gaps identified in Week 2

Figure 4.1 (below) summarizes, layer by layer, how the six CSF 2.0 functions map onto the four Annex A themes, distinguishing direct correlations (solid) from partial correlations (dotted).

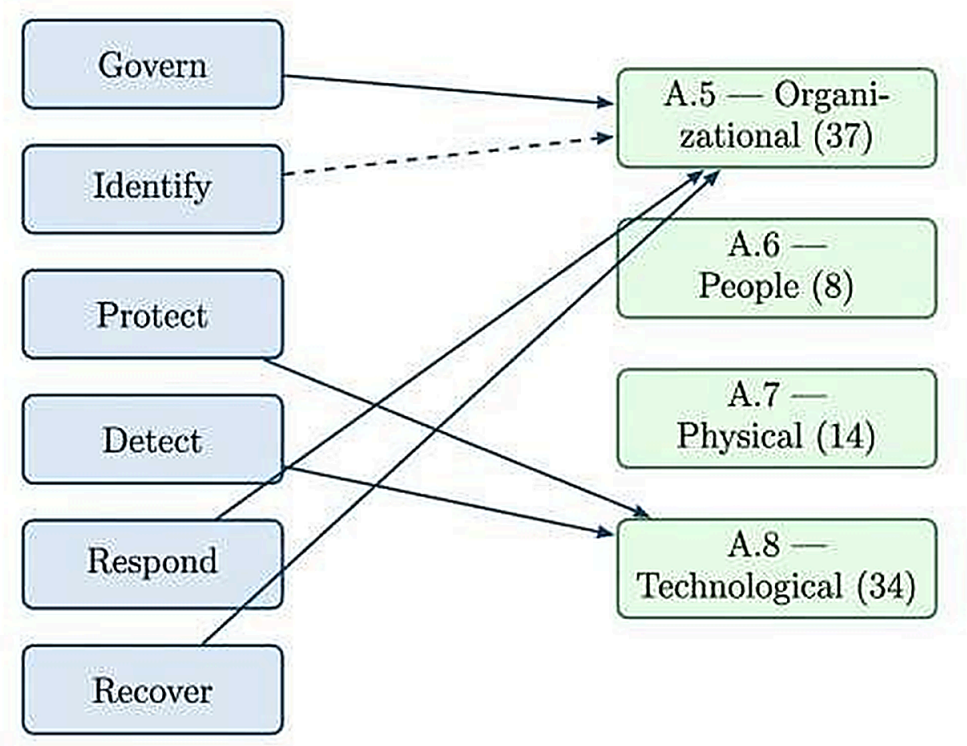


Figure 4.1: Overview of the NIST CSF 2.0 × ISO/IEC 27001:2022 Annex A mapping (solid = direct correlation, dotted = partial correlation)

Key takeaway. The visualization confirms that the Protect and Detect functions converge heavily on the A.8 — Technological theme, which concentrates 34 controls; it is precisely within this theme that the five identified cloud-native gaps must be resolved as a priority, which directly shaped the design of the blueprint in Week 3.

4.4 Week 3 — Integrated Cybersecurity Management Blueprint

4.4.1 Three-Layer Architecture

To move beyond a simple list of controls, the blueprint was structured into three independently auditable layers: governance, core controls, and cloud-native extensions, as illustrated in Figure 4.2.

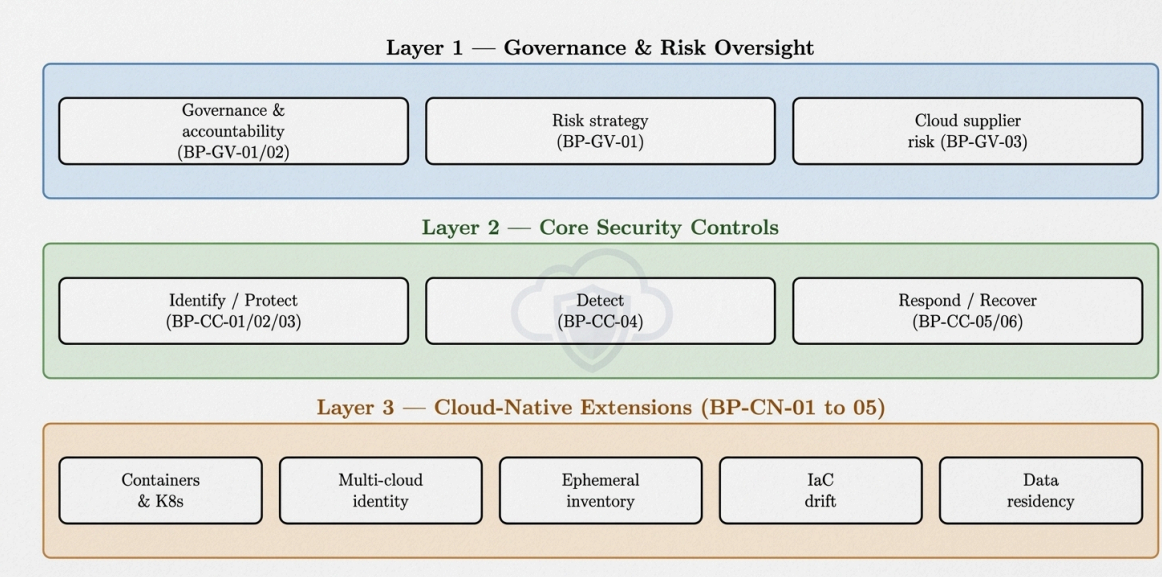


Figure 4.2: Three-layer architecture of the Integrated Cybersecurity Management Blueprint

Key takeaway. This layered architecture allows each level to evolve at its own pace: governance changes rarely, core controls evolve with framework revisions, while the cloud-native layer can be updated frequently to keep pace with rapidly changing tools (Kubernetes, Terraform, CI/CD).

4.4.2 Layer 1 — Governance and Risk Oversight

Control	Description	CSF / ISO ref.
BP-GV-01	Unified cloud risk register, covering multi-cloud and multi-tenant exposure, reviewed quarterly by leadership	GV.RM-01 / Clause 6.1 + A.5.1
BP-GV-02	Shared-responsibility policy explicitly documenting CSP/customer boundaries for each cloud service	GV.OC-01 / A.5.1

BP-GV-03	Cloud supplier risk program, with assessment prior to onboarding and at renewal	GV.SC-01 / A.5.19–5.23

Table 4.6: Blueprint controls — Governance layer

4.4.3 Layer 2 — Core Security Controls

Control	Description	CSF / ISO ref.
BP-CC-01	Vulnerability identification, extended to container images and IaC templates	ID.RA-01 / A.8.8
BP-CC-02	Privileged identity and access management, extended to multi-cloud SSO/IdP federation	PR.AA-01 / A.5.16+A.8.2
BP-CC-03	Data-at-rest protection, extended to CSP-managed key stores (KMS)	PR.DS-01 / A.8.24
BP-CC-04	Centralized monitoring of network and cloud services, feeding a central SIEM	DE.CM-01 / A.8.16
BP-CC-05	Incident response execution, extended to CSP notification SLAs and shared forensic access	RS.MA-01 / A.5.24–5.26
BP-CC-06	Recovery plan execution, extended to multi-region failover testing	RC.RP-01 / A.5.29–5.30

Table 4.7: Blueprint controls — Core Controls layer

4.4.4 Layer 3 — Cloud-Native Extensions

This layer directly resolves the five gaps identified in Week 2, with controls formulated in concrete technical terms (Kubernetes, Docker, Terraform, CI/CD pipelines) rather than generic language.

Control	Description	CSF / ISO ref.
BP-CN-01	Mandatory container image scanning before publication + Kubernetes admission control (OPA Gatekeeper / Kyverno) blocking any non-compliant pod	PR.PS / A.8.8, A.8.9
BP-CN-02	Documented multi-cloud identity federation model (IdP) with break-glass fallback procedure	PR.AA-01 / A.5.16
BP-CN-03	Asset inventory continuously fed from the cloud provider's API and tagging system (AWS Config, Azure Resource Graph)	ID.AM-01 / A.5.9
BP-CN-04	Automated IaC scanning (Checkov, OPA) integrated into the CI/CD pipeline as a policy gate before deployment	PR.PS-01 / A.8.9
BP-CN-05	Data-residency notification matrix by region, specifying regulator and customer contacts to alert	RC.CO-03 / A.5.24

Table 4.8: Blueprint controls — Cloud-native Extension layer



Figure 4.3: CI/CD pipeline security gate implementing BP-CN-04 (failed scans block the pipeline and open a ticket)

Key takeaway. BP-CN-04 (the CI/CD gate) is identified as the most directly actionable control in the blueprint: it can be automated without depending on a manual review process, unlike most other cloud-native controls, which require prior organizational formalization (federation model, notification matrix).

Control	Layer	CSF 2.0 ref.	ISO Annex A ref.
BP-GV-01 – 03	Governance	GV.RM-01, GV.OC-01, GV.SC-01	Cl.6.1+A.5.1, A.5.1, A.5.19–5.23
BP-CC-01 – 06	Core Controls	ID.RA-01, PR.AA-01, PR.DS-01, DE.CM-01, RS.MA-01, RC.RP-01	A.8.8, A.5.16+A.8.2, A.8.24, A.8.16, A.5.24–5.26, A.5.29–5.30
BP-CN-01 – 05	Cloud-native Extension	PR.PS, PR.AA-01, ID.AM-01, PR.PS-01, RC.CO-03	A.8.8–A.8.9, A.5.16, A.5.9, A.8.9, A.5.24

Table 4.9: Consolidated matrix of the Blueprint's 14 controls

4.5 Week 4 — Crosswalk Compliance Guide

4.5.1 Dual-Audience Structure

The blueprint was translated into a crosswalk compliance guide addressing two distinct audiences from the same control matrix, ensuring no divergence between the two views.

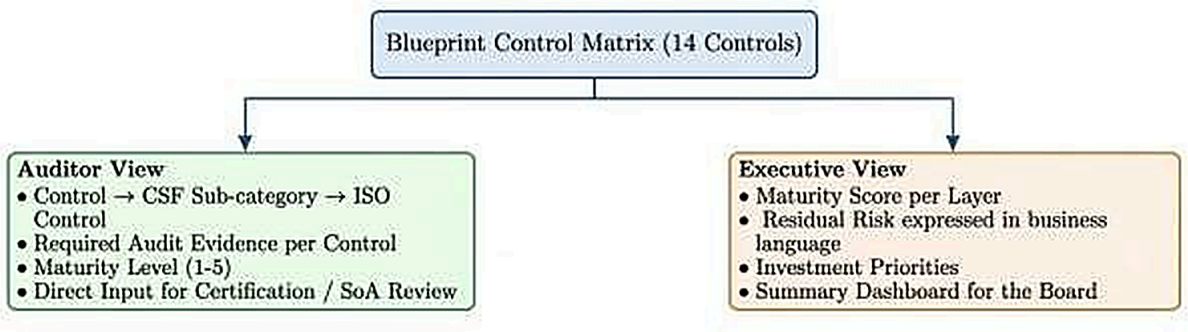


Figure 4.4: Dual-audience structure of the crosswalk compliance guide

Auditor view — Control → CSF subcategory → ISO control; required audit evidence per control; maturity level (1–5); direct input for certification review / SoA.

Executive view — Maturity score by layer; residual risk expressed in business language; investment priorities; summary dashboard for the board.

4.5.2 Auditor View — Traceability and Maturity

Control	Expected audit evidence	Maturity
BP-GV-01	Approved risk register, multi-cloud/tenant entries	3 — Defined
BP-CC-03	KMS key inventory, encryption policy	4 — Managed
BP-CC-06	Recovery test reports including failover exercises	2 — Repeatable
BP-CN-01	Container image scan logs, admission control policy	2 — Repeatable
BP-CN-04	CI/CD pipeline scan logs (Checkov, OPA)	2 — Repeatable
BP-CN-05	Per-region data-residency notification matrix	1 — Initial

Table 4.10: Excerpt of the Auditor view — evidence and maturity per control

4.5.3 Executive View — Maturity by Layer

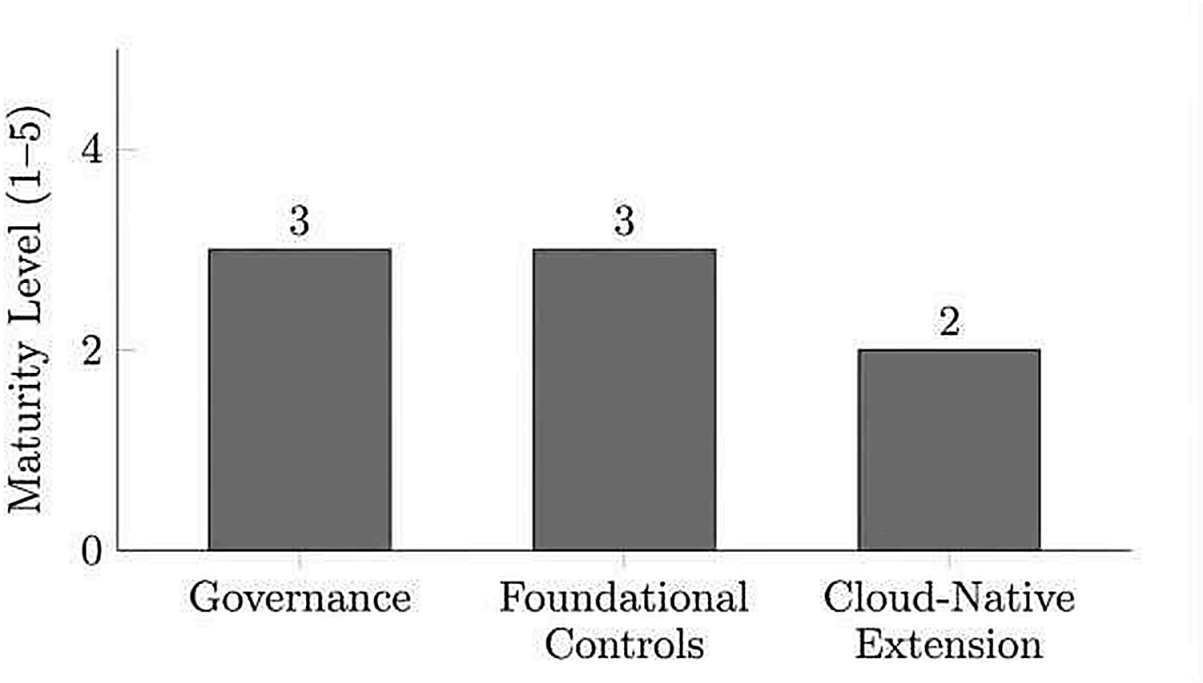


Figure 4.5: Aggregated maturity by Blueprint layer (qualitative assessment, end of internship) — scale 1–5

Key takeaway. *The Cloud-native Extension layer shows the lowest maturity (level 2 — Repeatable), confirming that it is the priority workstream for any organization seeking to operationalize this blueprint. Control BP-CN-05 (data residency) is the least mature control overall (level 1 — Initial) and represents the main follow-up workstream identified at the end of the internship.*

Layer	Business risk	Recommended priority
Governance	Unclear responsibility boundaries with cloud suppliers, potentially slowing incident response	Medium — finalize and sign BP-GV-02 this quarter
Core Controls	Well covered for certification purposes, but multi-region disaster recovery not yet tested	Medium — plan the first failover exercise
Cloud-native Extension	Least mature layer, area most exposed to configuration drift	High — prioritize BP-CN-04 and BP-CN-01, which can be automated quickly

Table 4.11: Recommended investment priorities by layer

4.6 Business Benefits of the Proposed Blueprint

Beyond its methodological coherence, the integrated blueprint offers concrete benefits for a cloud-native organization, summarized below.

Benefit	Description
Simplified compliance	A single control matrix simultaneously satisfies NIST CSF 2.0 and ISO/IEC 27001:2022 requirements, avoiding duplicated effort between compliance and security teams.
Easier audits	The Auditor view provides direct traceability between each blueprint control, the corresponding CSF subcategory, the associated ISO control, and the expected audit evidence, reducing certification-audit preparation time.
Strengthened cloud security	The cloud-native extension layer explicitly closes the blind spots (containers, IaC, multi-cloud identity) that neither CSF 2.0 nor ISO/IEC 27001 natively covers, reducing real exposure to modern risks.
Improved governance	The Executive view translates technical maturity into business language (residual risk, investment priorities), facilitating decision-making and budget allocation at the board level.
Reduced operational risk	Automating key controls (IaC scanning, image scanning, Kubernetes admission control) reduces reliance on manual reviews prone to human error.
Scalability & durability	The three independently auditable layers allow cloud-native controls to evolve at the fast pace of technology change without disrupting the more stable governance layer.

Table 4.12: Expected business benefits of the integrated Blueprint

Key takeaway. Cross-referencing the operational findings from the first month (Chapter 3) with the second month's blueprint shows that several recurring vulnerabilities identified during the audits — missing CSP, DNSSEC not enabled, obsolete components — fall precisely within the Governance and Core Controls layers of the blueprint. This confirms the operational relevance

of the proposed framework: it is not an isolated academic exercise, but a tool directly applicable to the field findings observed during the internship.

4.7 Conclusion

This second month made it possible to transform an initial literature review into a complete strategic deliverable: a detailed mapping, a three-layer, fourteen-control cybersecurity management blueprint, and a dual-audience crosswalk compliance guide. The cloud-native layer, the least mature at this stage, is the main recommended workstream beyond this internship.

General Conclusion

This two-month internship at IFGICT, under the supervision of Dr. KAYYALI, made it possible to approach cybersecurity from two complementary and progressive angles.

The first month, dedicated to carrying out six complete web security audits, made it possible to develop solid operational expertise: authorized passive and active reconnaissance, analysis of HTTP headers and TLS/DNS configuration, identification of obsolete components, and the writing of structured professional reports with prioritized remediation plans. The results obtained — grades ranging from F (unacceptable) to B (good) — highlighted recurring vulnerability patterns, notably the near-systematic absence of HTTP security headers and DNSSEC.

The second month made it possible to step back from these field findings by conducting in-depth research on the alignment between the NIST Cybersecurity Framework 2.0 and ISO/IEC 27001:2022. This work resulted in the design of a three-layer integrated cybersecurity management blueprint, comprising fourteen controls traceable to both frameworks, as well as a crosswalk compliance guide intended for both auditors and executives. The business benefits of this blueprint — simplified compliance, easier audits, strengthened cloud security, and improved governance — make it a tool directly usable beyond the academic scope of this internship.

On a personal level, this internship was a formative experience in two respects: it made it possible to consolidate concrete technical skills in security auditing, while developing the strategic analysis and synthesis capabilities essential to any cybersecurity governance assignment. The quality and progressive structuring of the weekly deliverables, praised by IFGICT's supervision, reflect this continuous skills growth throughout the two months.

Looking ahead, the work initiated during this internship — notably the operational validation of the blueprint (piloting the CI/CD gate, a first multi-region failover exercise, the data-residency matrix) — opens the way to follow-up work that I intend to pursue as I continue along this path in cybersecurity.

References

1. OWASP Foundation. OWASP Web Security Testing Guide (WSTG) v4.2. https://owasp.org/www-project-web-security-testing-guide/

2. OWASP Foundation. OWASP Top 10 – 2021. https://owasp.org/www-project-top-ten/

3. Penetration Testing Execution Standard (PTES). http://www.pentest-standard.org/

4. ISECOM. Open Source Security Testing Methodology Manual (OSSTMM) 3. https://www.isecom.org/OSSTMM.3.pdf

5. NIST SP 800-115. Technical Guide to Information Security Testing and Assessment. National Institute of Standards and Technology.

6. Qualys SSL Labs. https://www.ssllabs.com/ssltest/

7. SecurityHeaders.com. https://securityheaders.com/

8. Certificate Transparency Logs – crt.sh. https://crt.sh/

9. NIST (2024). The NIST Cybersecurity Framework (CSF) 2.0. National Institute of Standards and Technology. https://doi.org/10.6028/NIST.CSWP.29

10. ISO/IEC (2022). ISO/IEC 27001:2022 – Information security, cybersecurity and privacy protection – Information security management systems – Requirements. International Organization for Standardization / International Electrotechnical Commission.

11. ISO/IEC (2022). ISO/IEC 27002:2022 – Information security, cybersecurity and privacy protection – Information security controls. International Organization for Standardization / International Electrotechnical Commission.

12. NIST. CSF 2.0 Reference Tool. https://csrc.nist.gov/projects/cybersecurity-framework

13. Open Policy Agent. Gatekeeper – Policy Controller for Kubernetes. Cloud Native Computing Foundation. https://open-policy-agent.github.io/gatekeeper/

14. MDN Web Docs. HTTP Headers Reference (CSP, HSTS, X-Frame-Options, Referrer-Policy, Permissions-Policy). https://developer.mozilla.org/en-US/docs/Web/HTTP

15. IETF. RFC 6797 – HTTP Strict Transport Security (HSTS). https://datatracker.ietf.org/doc/html/rfc6797

16. IETF. RFC 7489 – Domain-based Message Authentication, Reporting and Conformance (DMARC). https://datatracker.ietf.org/doc/html/rfc7489

17. IETF. RFC 8659 – DNS Certification Authority Authorization (CAA) Resource Record. https://datatracker.ietf.org/doc/html/rfc8659

18. ICANN. DNSSEC – What Is It and Why Is It Important? https://www.icann.org/resources/pages/dnssec-what-is-it-why-important-2019-03-05-en